

PKI, TLS, web browsers and certificate revocation - theory vs practice

Irek Pastusiak

CorkSec June 2025

Context

BULLETPROOF SSL AND TLS

Understanding and Deploying SSL/TLS and
PKI to Secure Servers and Web Applications



Ivan Ristić



BULLETPROOF TLS AND PKI

SECOND
EDITION

Understanding and Deploying SSL/TLS and
PKI to Secure Servers and Web Applications



Ivan Ristić



*"Everything you never wanted to know
about PKI but were forced to find out"*

Peter Gutmann

Why do we need
X.509 certificates?

Why do we need
certificate revocation?

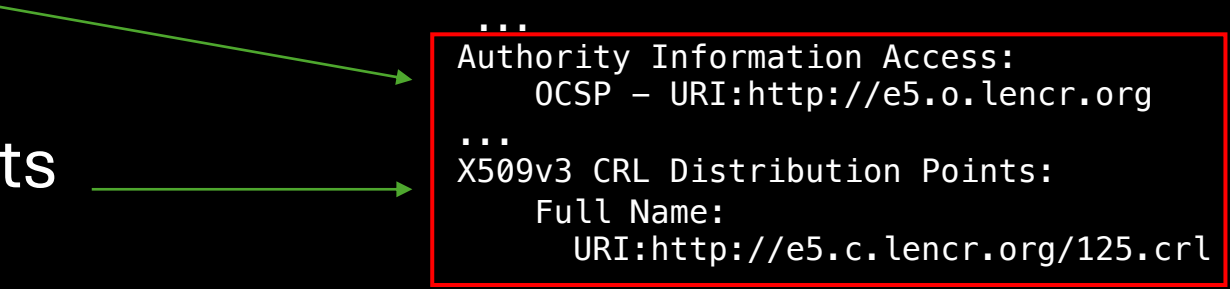
Certificate revocation in theory

Online Certificate Status
Protocol (OCSP)

Certificate Revocation Lists
(CRLs)

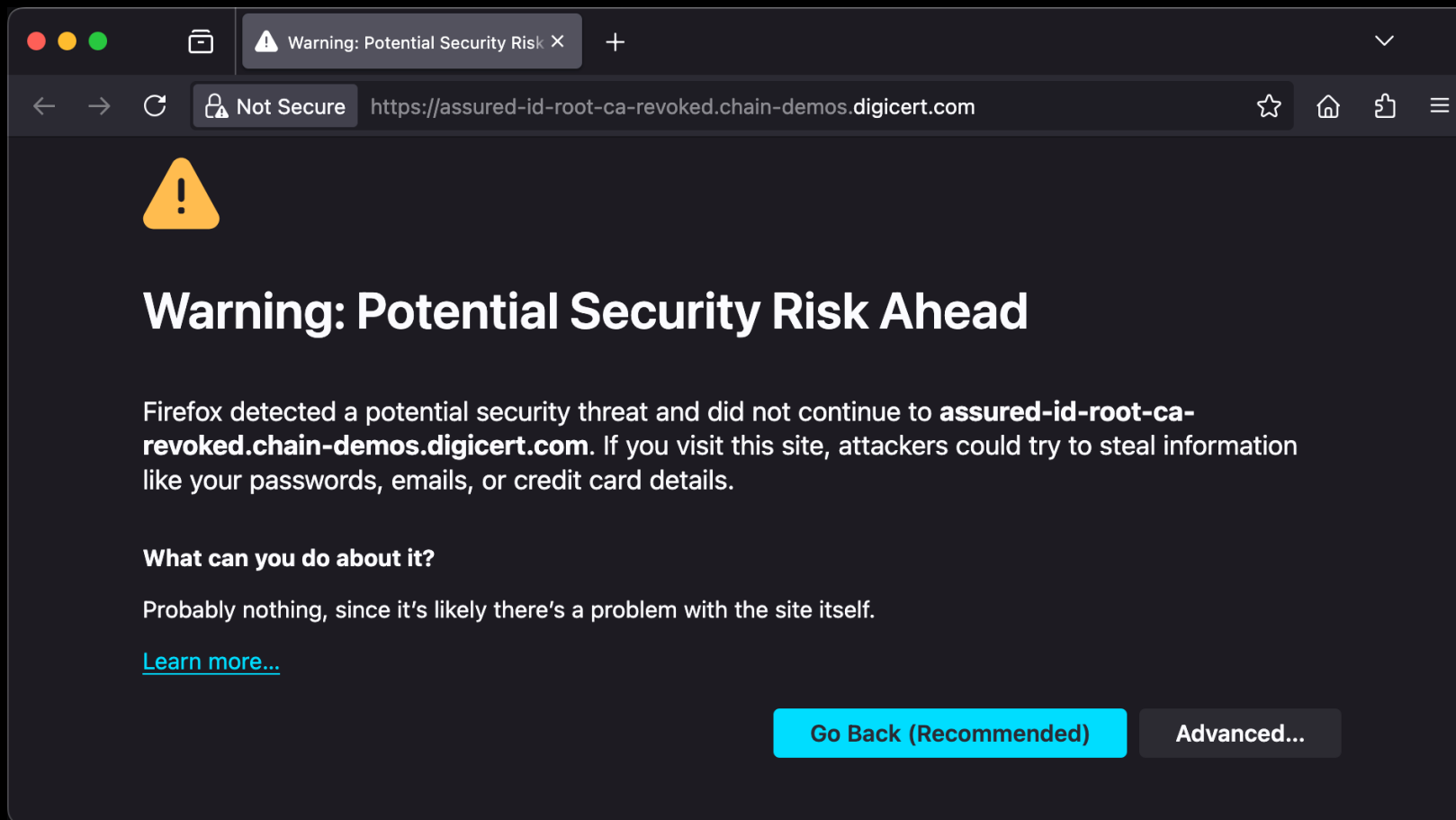
```
Certificate:
  Data:
    Version: 3 (0x2)
    Serial Number:
      05:ce:00:a4:15:b9:41:32:5c:29:4e:31:68:2c:36:b5:b7:fc
    Signature Algorithm: ecdsa-with-SHA384
    Issuer: C=US, O=Let's Encrypt, CN=E5
    Validity
      Not Before: Apr 29 20:03:06 2025 GMT
      Not After : Jul 28 20:03:05 2025 GMT
    Subject: CN=revoked.badssl.com

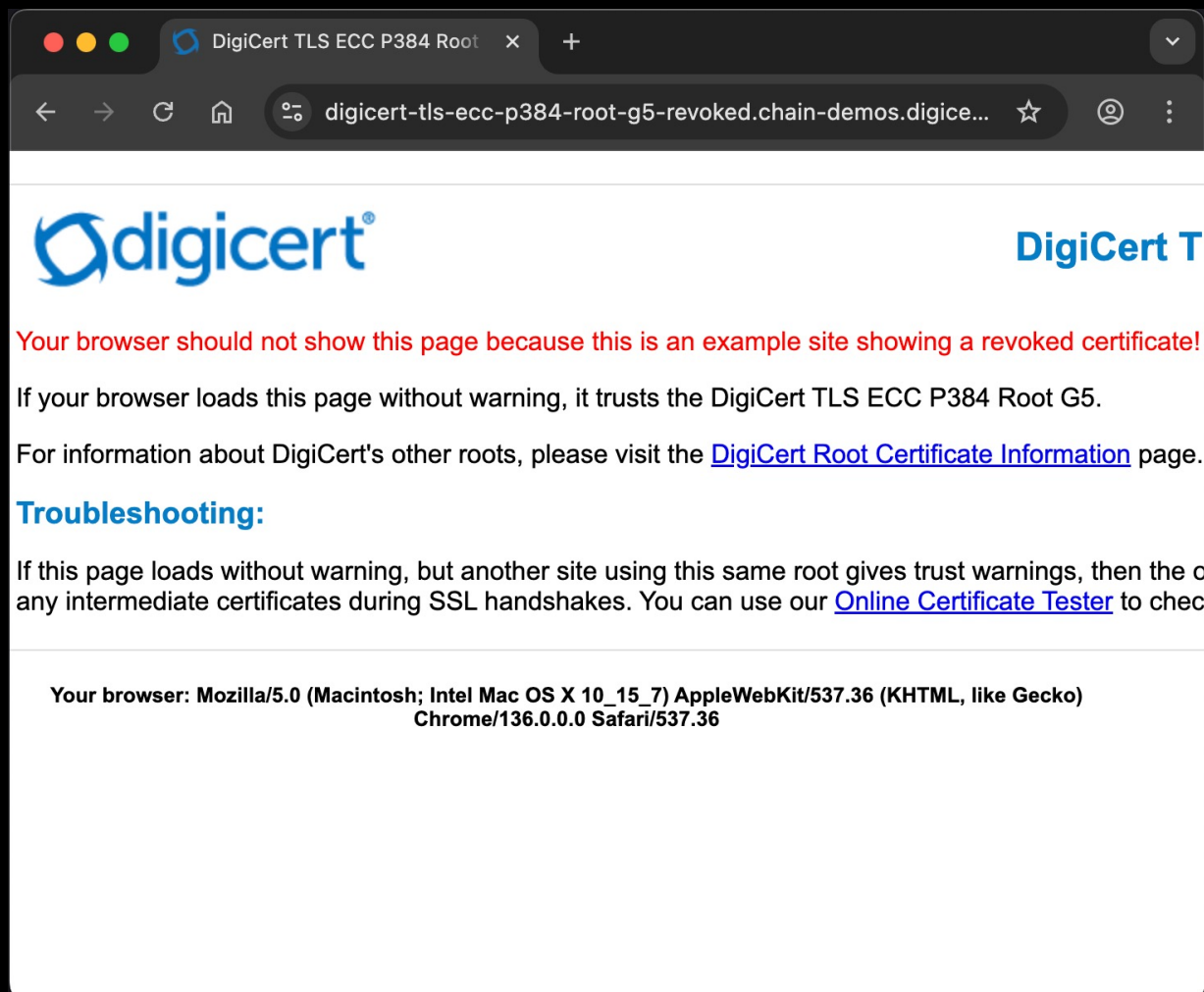
    ...
  X509v3 extensions:
    ...
    Authority Information Access:
      OCSP - URI:http://e5.o.lencr.org
    ...
    X509v3 CRL Distribution Points:
      Full Name:
        URI:http://e5.c.lencr.org/125.crl
```

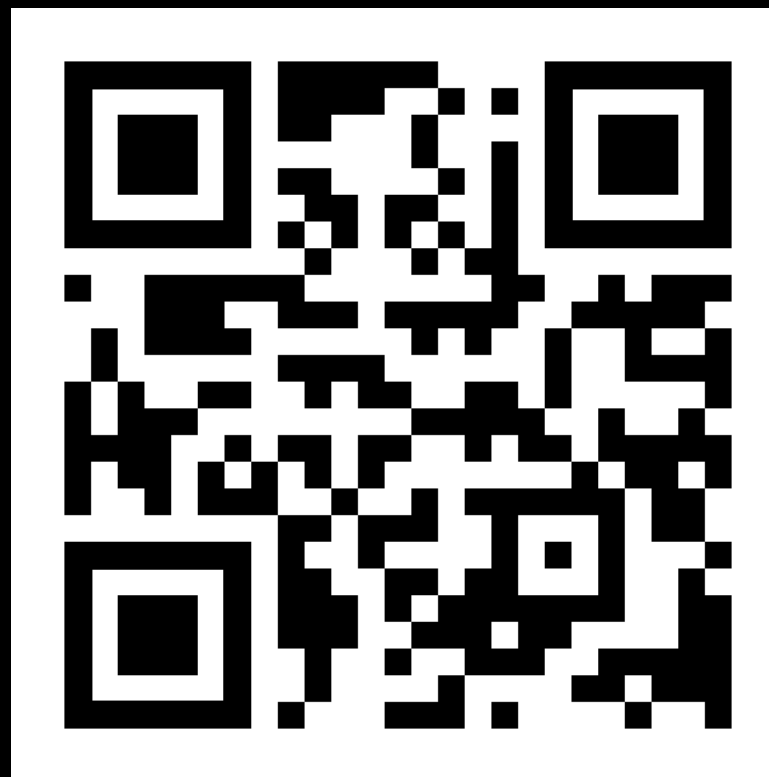
A diagram with two green arrows pointing from the text on the left to a red-bordered box on the right. The first arrow points from 'Online Certificate Status Protocol (OCSP)' to the 'Authority Information Access' section of the certificate extensions. The second arrow points from 'Certificate Revocation Lists (CRLs)' to the 'X509v3 CRL Distribution Points' section of the same extensions.

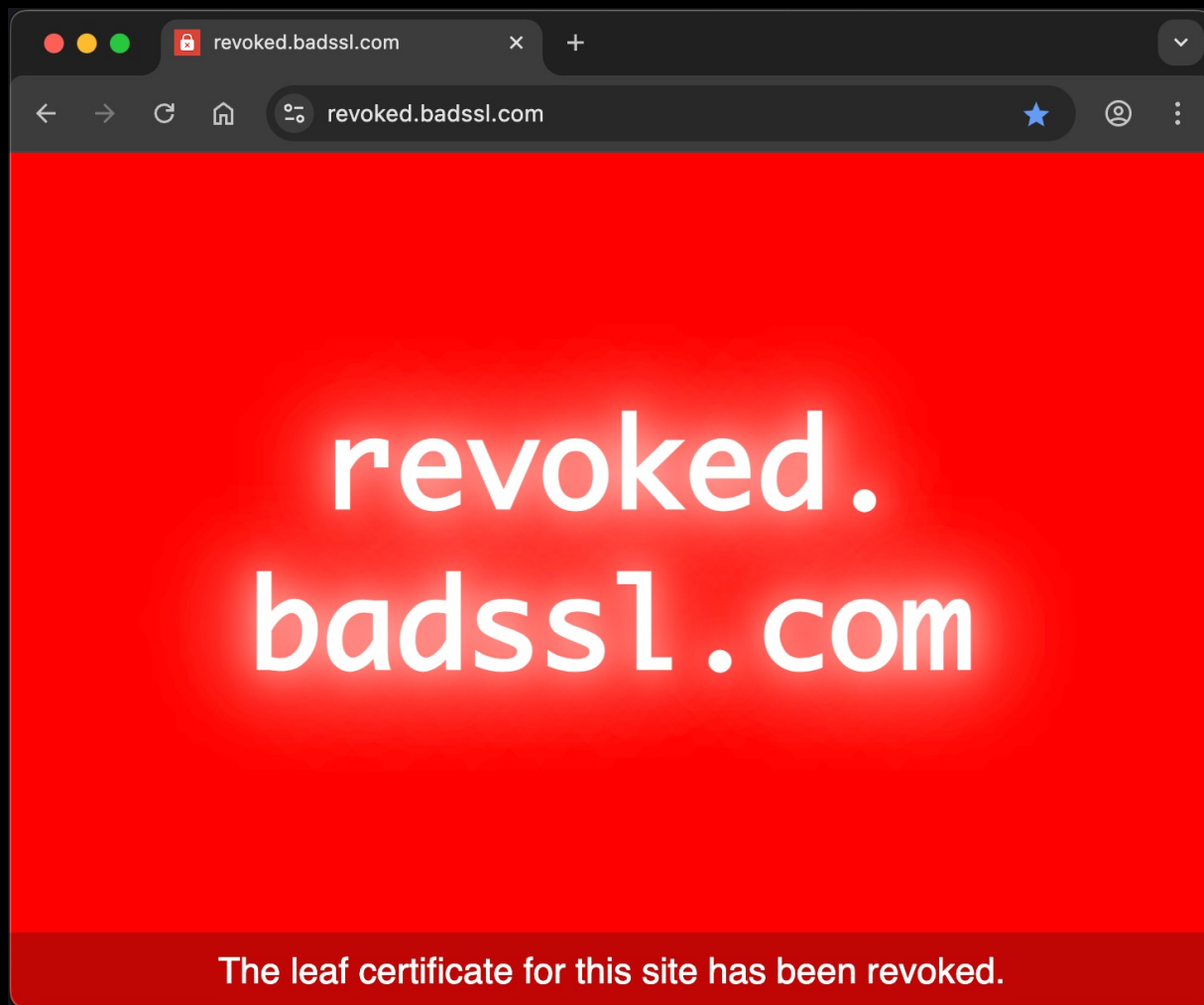
Certificate revocation in practice

- No single standard covering revocation end-to-end
- Your mileage may vary:
 - Browser
 - Operating system
 - etc.









How did we get there – part 1

CRL

Theoretical problems with CRLs

- Freshness
- Size and bandwidth
- Client support

Practical problems with CRLs

- None – because they are not being used
(at least not the way most people would expect)

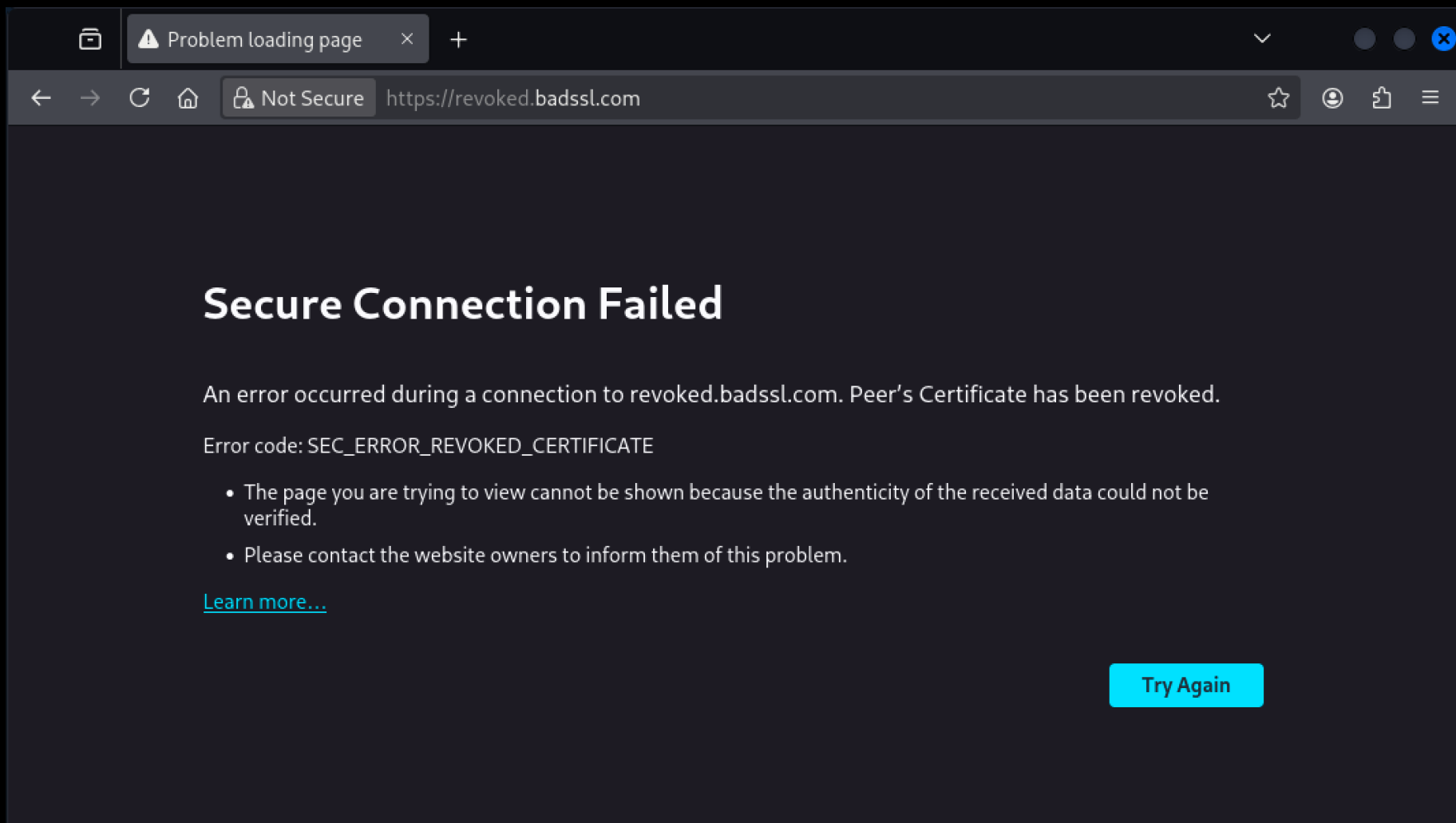
How did we get there – part 2

CRL → OCSP

Problems with OCSP

- Privacy
- Responder availability
- Response suppression
- Client support
- Soft-fail
- Bandwidth
- Freshness (again...)
- etc.

Suppressing OCSP response



Capturing from eth0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ocsp

No.	Time	Source	Destination	Protocol	Length	Info
49	0.616961864	10.0.2.4	23.216.154.169	OCSP	484	Request
50	0.617593914	10.0.2.4	23.216.154.169	OCSP	484	Request
51	0.617967401	10.0.2.4	23.216.154.169	OCSP	484	Request
52	0.682174540	23.216.154.169	10.0.2.4	OCSP	809	Response
55	0.692075730	23.216.154.169	10.0.2.4	OCSP	809	Response
59	0.696072250	23.216.154.169	10.0.2.4	OCSP	809	Response

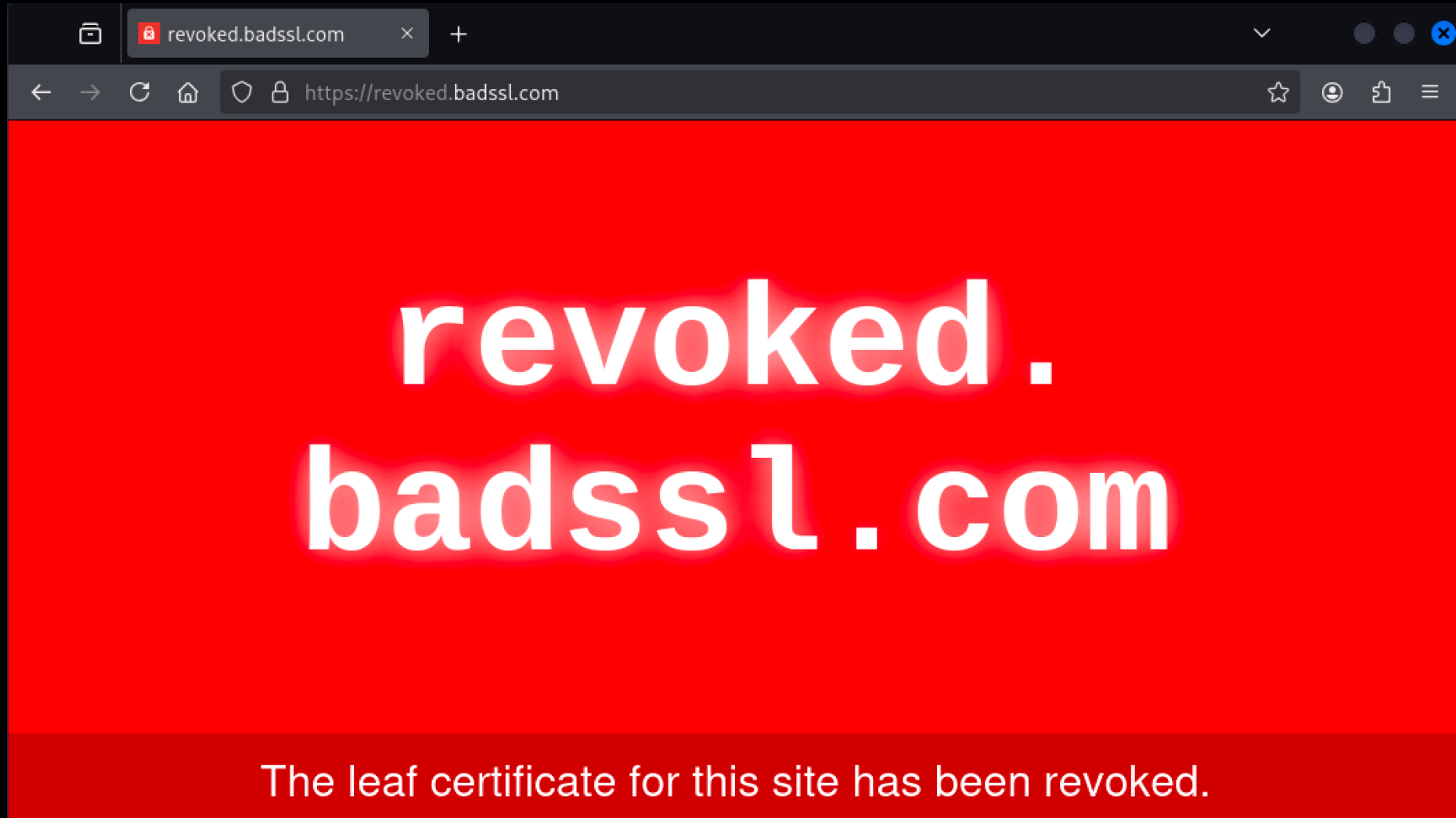
```
responseStatus: successful (0)
  responseBytes
    ResponseType Id: 1.3.6.1.5.5.7.48.1.1 (id-pkix-ocsp-basic)
    BasicOCSPResponse
      tbsResponseData
        responderID: byName (1)
          producedAt: May 22, 2025 11:09:00.000000000 IST
          responses: 1 item
            SingleResponse
              certID
                hashAlgorithm (SHA-1)
                  Algorithm Id: 1.3.14.3.2.26 (SHA-1)
                  issuerNameHash: 1e11c0c9acfda453ef4b2f6a732115604d54adb9
                  issuerKeyHash: 99cd29c3a15826af7a7a4c845a8f738860b0dfde
                  serialNumber: 0x05ce00a415b941325c294e31682c36b5b7fc
              certStatus: revoked (1)
                revoked
                  revocationTime: Apr 29, 2025 22:01:40.000000000 IST
                  revocationReason: keyCompromise (1)
                  thisUpdate: May 22, 2025 11:09:00.000000000 IST
                  nextUpdate: May 29, 2025 11:08:58.000000000 IST
              signatureAlgorithm (ecdsa-with-SHA384)
                Algorithm Id: 1.2.840.10045.4.3.3 (ecdsa-with-SHA384)
                Padding: 0
                signature: 3066023100b6323b0d1c7accfe2cd8cb9cec053b9c06dedc41ab744f6d07d9c1ba70583c06b
```

```
127.0.0.1    localhost
127.0.1.1    kali
127.0.0.1    e5.o.lencr.org

# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
```

```
└─$ sudo nc -l -p 80 -s 127.0.0.1
POST / HTTP/1.1
Host: e5.o.lencr.org
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/ocsp-request
Content-Length: 85
Connection: keep-alive
Priority: u=2
Pragma: no-cache
Cache-Control: no-cache

0S0Q000M0K0      +███!♦♦♦S♦K/js!`MT♦♦♦♦)áXδ♦zzL♦Z♦s♦`♦♦♦♦♦♦A2\N1h,6♦♦♦
```



Advanced Preferences

×

+

←

→

↻

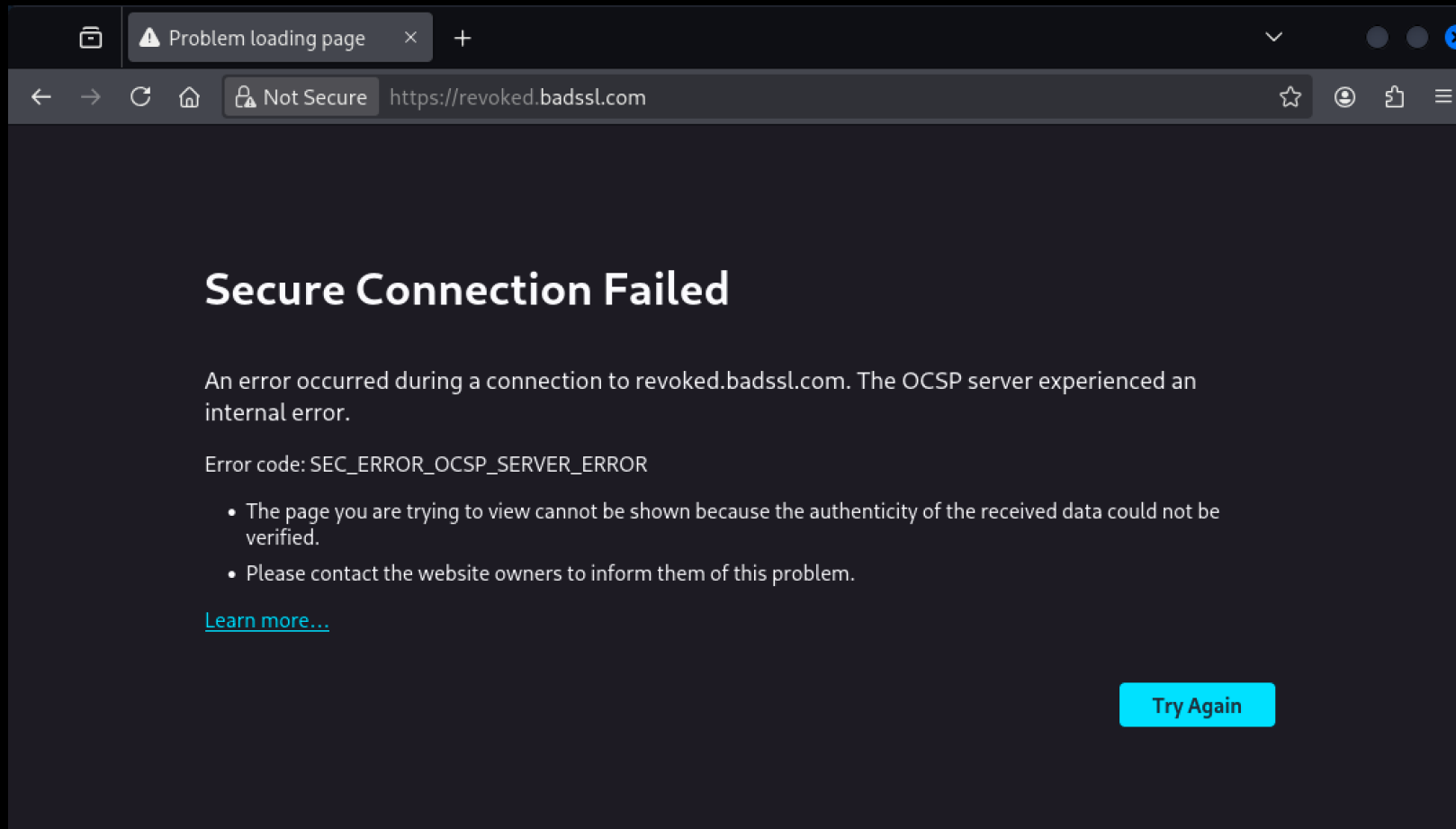
🏠

Firefox

about:config

🔍 ocs

privacy.partition.network_state.ocsp_cache.pbmode	true
security.OCSP.enabled	1
security.OCSP.require	true
security.OCSP.timeoutMilliseconds.hard	10000
security.OCSP.timeoutMilliseconds.soft	2000
security.ssl.enable_ocsp_must_staple	true
security.ssl.enable_ocsp_stapling	true



How did we get there – part 3

CRL → OCSP → OCSP Stapling

Capturing from Wi-Fi: en0

ocsp and tls

No.	Time	Source	Destination	Protocol	Length	Info
153...	57.757476	199.232.26.133	192.168.8.111	TLSv1.2	1019	Certificate, Certificate Status, S

OCSP Response

responseStatus: successful (0)

responseBytes

ResponseType Id: 1.3.6.1.5.5.7.48.1.1 (id-pkix-ocsp-basic)

BasicOCSPResponse

tbsResponseData

responderID: byKey (2)

producedAt: May 23, 2025 21:30:39.000000000 IST

responses: 1 item

SingleResponse

certID

hashAlgorithm (SHA-1)

issuerNameHash: 777a7ba877d6f10f1ce9202196fb6b1a6e37f5ed

issuerKeyHash: 9058ffb09c75a8515477b1edf2a34316389e6cc5

serialNumber: 0x0a11bd591b40aaa75841e305d6db945a

certStatus: good (0)

thisUpdate: May 23, 2025 21:15:01.000000000 IST

nextUpdate: May 30, 2025 20:15:01.000000000 IST

signatureAlgorithm (sha256WithRSAEncryption)

Padding: 0

signature [...]: 80975fe91e838168002fca711a8694581c7eb983bedda9dbfa422e67e9052c85349f53b1b40faf9616b3d0da0

certStatus (ocsp.certStatus)

Packets: 23938 · Displayed: 1 (0.0%)

Sample bandwidth numbers

"83 billion CDN hits per week.

11 billion origin hits per week.

or

~137,000 CDN hits per second.

~18,000 origin hits per second."

(numbers from Let's Encrypt, blog post dated 30 Dec 2024)

We live in interesting times

- Let's Encrypt ending OCSP support
 - 7 May 2025 – removed OCSP URLs from certificates
 - 6 August 2025 – will shut down OCSP responders

Let's Encrypt ending OCSP support

"For every year that we have existed, operating OCSP services has taken up considerable resources that can soon be better spent on other aspects of our operations"

How did we get there – part 4



Welcome CRLs in real life!

- Chrome CRLSet – covers some revocations
- Firefox CRLite – covers all revocations *
- etc.

* - caveats apply

Chrome CRLSet

"CRLSets are the primary means by which Chrome quickly blocks certificates in emergency situations."

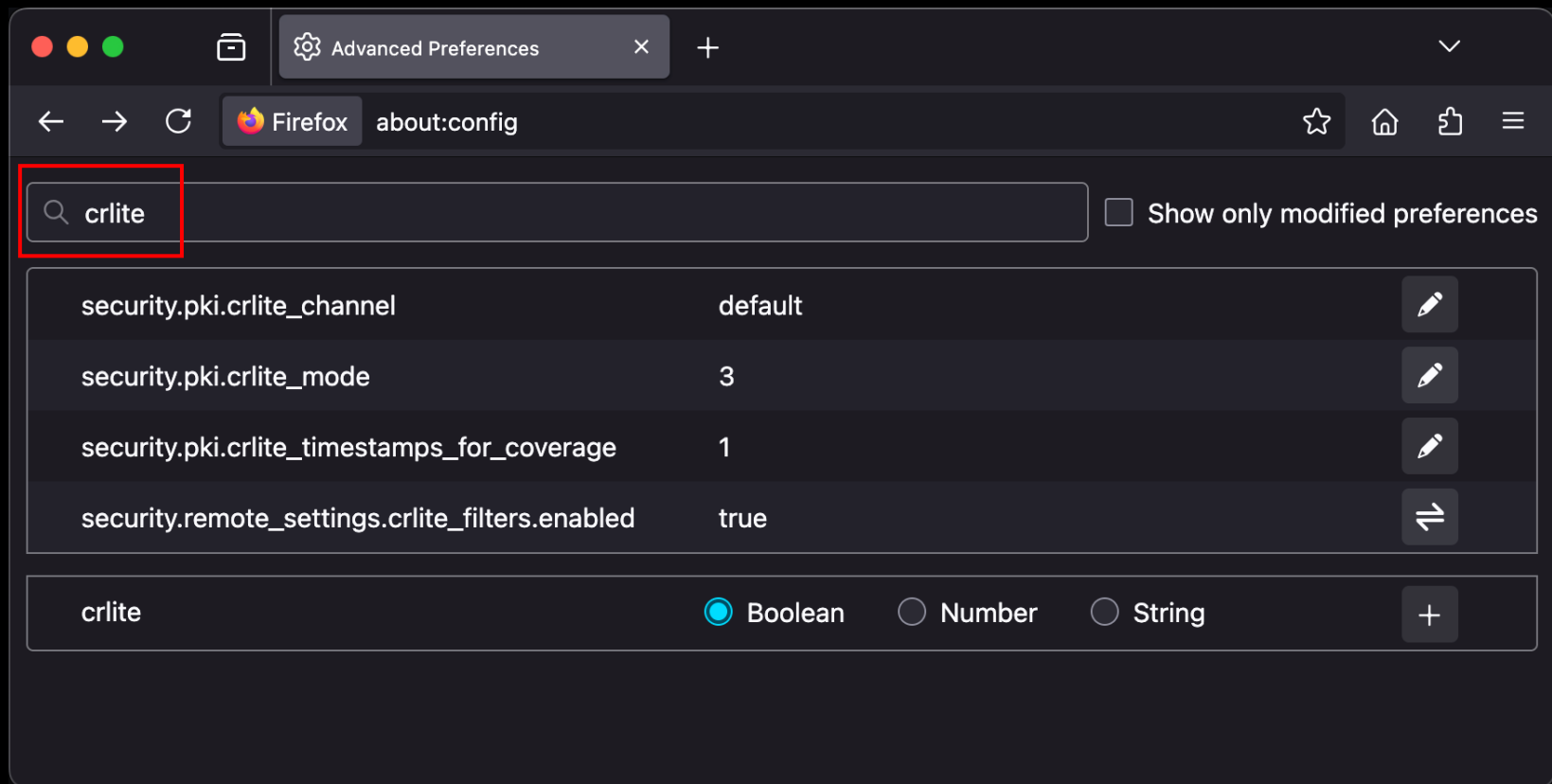
"Online (i.e. OCSP and CRL) checks are not, generally, performed by Chrome."

"The Chromium source code that implements CRLSets is, of course, public. But the process by which they are generated is not."

Firefox CRLite

- New piece of technology
- Bloom filters for small footprint
- Aims at collecting revocation data from all CAs *
- Configurable and still aided by OCSP (where possible)

* - caveats apply



What can I do?

- Use a browser you feel comfortable with
- Configure your browser

Bonus content

DNS Certification Authority Authorization

- RFC 8659
- example.com CAA 0 issue ";"
- example.com CAA 0 issue "letsencrypt.org"

DNS Certification Authority Authorization

"Upon checking your domain [...], I can see that there is a CAA record present on your domain that prevents us from installing SSL on your website. [...] issues SSL for all the domains hosted on its server for free. We do not upload existing SSL for domains bought elsewhere.

In this case, please log in to [...], where you got this domain, and remove the CAA record for the domain [...]"

Question time